Executive Memo: Security Risk Assessment

Anita & Daughters is a fictional company. This memo is part of a learning project.

To: Anita Williams, Founder and CEO
From: Aaesha Tobias, Security Analyst
Date: October 27, 2026
Re: Where our biggest security risks are, and what to do first

Bottom line

I reviewed the 18 systems and assets we use to handle patient billing information and found 15 risks: **2 Critical, 7 High, 5 Medium, and 1 Low**. The two Critical risks are staff phishing and ransomware on our file server. Many of the fixes are low-cost steps such as turning on MFA, writing down rules, and training staff. Six priority actions, due by January 29, 2027, would address both Critical risks.

Our five biggest risks

ID	What could happen	Score	Rating
R-01	A phishing email captures a staff password, and an attacker reads patient information in that person's mailbox and files. Only the 2 IT admin accounts use MFA today.	**20**	**Critical**
R-02	Ransomware locks the file server and billing work stops for days. The server is patched irregularly and laptops are not centrally managed.	**20**	**Critical**
R-05	Attackers guess or reuse a password and log in to the VPN. The VPN accepts a password alone.	**16**	**High**
R-03	A failed backup leaves us unable to recover. Restores have never been tested.	**15**	**High**
R-10	With no written incident plan, staff do not know who to call, and we could miss a breach notice deadline to a client.	**12**	**High**

Scores are likelihood times impact, each rated 1 to 5. The full list of 15 is in the Risk Register.

What I recommend first

1. **Turn on MFA** for all 50 staff accounts and the VPN (by Dec 15, 2026).
2. **Test restoring the file server from backup** and stop sharing the backup console password (by Nov 30, 2026).
3. **Train all staff** in English and Thai, including a phishing test (by Dec 18, 2026).
4. **Patch the file server monthly** and turn on automatic updates on laptops (by Dec 31, 2026).
5. **Scan for weaknesses** every quarter and fix the serious ones (first scan by Jan 15, 2027).
6. **Put all laptops under central management** with a standard security setup (by Jan 29, 2027).

The other 15 actions, from policies and incident contacts to locked cabinets, are in the Remediation Plan with owners and dates.

Where we stand today

I checked us against 24 controls from the NIST Cybersecurity Framework 2.0. **3 are in place, 10 are partly in place, and 11 are missing.** That leaves 21 gaps, and each one has a named owner, a due date, and a way to prove it is fixed. I have drafted three policies (access control, incident response, and acceptable use) that close several of the gaps once approved.

Decisions I need from you

- **Approve and sign the three policies by November 30, 2026**, then have every employee sign that they have read them.
- **Decide how to get IT more help.** Our IT team of 2 owns 11 of the 21 actions. Outside support or a device management tool would keep the dates realistic.
- **Confirm the action owners** I named, and ask them to report progress to the Compliance and Privacy Officer each month.

Scores and starting conditions are assumptions invented for this fictional firm and would need to be checked against the real environment. Breach notification deadlines should be confirmed with an attorney and each client contract. Supporting files: risk-assessment.xlsx and the policies folder.